

Protecting Patient Financial Data: A Legal and Policy Analysis Supporting the Proposed Illinois Medical Payment Data Protection Act of 2027

Roman Segal

Texas A&M University School of Law

Cybersecurity Law 760

June 2026

I. Introduction

Healthcare organizations in the United States occupy a uniquely dangerous position in the modern cybersecurity landscape. They possess not only sensitive clinical information but also the payment card data of millions of patients — data that hackers can exploit for immediate financial gain. Yet current law leaves a critical gap: while the Health Insurance Portability and Accountability Act (HIPAA) governs protected health information (PHI), it does not regulate how healthcare providers store or manage cardholder data.¹² Patients are routinely required to place a credit card "on file" as a condition of receiving care, often with no meaningful notice or the ability to refuse. This practice exposes them to financial fraud risk that existing federal law does not adequately address.

The Illinois Medical Payment Data Protection Act of 2027 (MPDPA), proposed in the 104th General Assembly, directly fills this void. The Act prohibits licensed healthcare providers from storing, keeping, or recording patient credit card information beyond the point of immediate, onetime processing; bars providers from requiring a card on file as a condition of care; mandates patient notification of these rights; and establishes civil penalties, private rights of action, and whistleblower protections for those who report violations.¹ This paper argues that the MPDPA represents sound, well-calibrated privacy legislation that reflects both the

cybersecurity threat environment and established legal principles, and that it should be enacted and used as a model for other states.

II. The Cybersecurity Threat Environment in Healthcare

A. Healthcare as the Costliest Target

Healthcare has been the most expensive sector for data breaches for fourteen consecutive years. In 2024, the average cost of a healthcare data breach reached \$9.77 million per incident — the highest across all industries.⁸ The human costs of healthcare breaches are severe: stolen medical records undermine clinical care, facilitate identity theft, and enable sophisticated financial fraud schemes that can take years to detect and reverse.

The reasons healthcare organizations attract attackers are well understood. They process personal, financial, and medical data simultaneously, creating extraordinarily rich targets.⁹ Many rely on legacy information technology systems that were not designed with modern security architectures in mind.¹⁰ The rapid expansion of electronic health records, telemedicine, and connected medical devices has vastly increased the attack surface without corresponding improvements in security. Healthcare providers also face operational pressures — during a ransomware event, refusing to pay a ransom can mean patient harm — that creates incentives for quick capitulation.

B. The Escalating Breach Landscape

Research analyzing breach data reported to the U.S. Department of Health and Human Services Office for Civil Rights (HHS-OCR) from 2019 through 2024 reveals an increasing frequency and severity of incidents, with large-scale events disproportionately affecting vast populations and network servers becoming the primary target.¹⁰ Hacking and IT incidents are the most prevalent and damaging breach types, with healthcare providers — not insurers or clearinghouses — being the most frequently targeted entities.⁹ A 239% increase in hacking-

related HIPAA breaches was recorded since 2018, along with a 278% increase in ransomware attacks over the same period.^{9,10}

The 2024 Change Healthcare cyberattack illustrated the systemic fragility at stake. That ransomware event paralyzed healthcare payment processing for months, affecting providers, suppliers, and patients across the country in ways that were unprecedented in scope. A medical record commands nearly four times the price of a Social Security number on the dark web, and nearly twenty times the value of a stolen credit card number, which explains why hackers have turned such intense focus on healthcare entities.⁹ Storing credit card data alongside health records only amplifies the value of any successful intrusion.

C. Payment Card Data: A Distinct and Unprotected Category

A fundamental regulatory gap exists at the intersection of healthcare and payment card security. HIPAA governs protected health information — clinical and demographic data linked to a patient's health condition or treatment — but it does not extend to payment card data as such.¹² The Payment Card Industry Data Security Standard (PCI DSS) was developed by major card networks to fill this gap by establishing minimum security requirements for entities that store, process, or transmit cardholder data. PCI DSS expressly discourages the storage of sensitive cardholder data, including full card numbers, beyond what is strictly necessary for completing a transaction.¹¹

The MPDPA's core prohibition directly codifies and enforces the PCI DSS principle in state law, converting a voluntary industry standard into a legal obligation for Illinois healthcare providers.¹¹¹ If the payment card industry itself has determined that storing cardholder data is unsafe and unnecessary, the state has a legitimate interest in ensuring that healthcare providers — who are high-value targets and often poorly resourced for cybersecurity — comply with this well-established best practice.

III. The Regulatory Framework: Gaps the MPDPA Fills

A. HIPAA's Structural Limitations

HIPAA, enacted in 1996 and updated through the HITECH Act of 2009, imposes privacy and security requirements on covered entities and their business associates with respect to PHI. Its administrative, physical, and technical safeguard requirements — enforced by HHS through civil and criminal penalties — have driven meaningful security improvements across the healthcare sector.¹² However, HIPAA's scope is limited by its definitions: payment card data is regulated by HIPAA only to the extent it becomes intertwined with health information. A provider that collects and retains a standalone credit card number for billing purposes may fall outside HIPAA's protective ambit.

The United States has no overarching general federal law on privacy, relying instead on sector-specific statutes such as HIPAA for healthcare and the Gramm-Leach-Bliley Act for financial institutions.⁴ This sectoralism leaves payment card data held by healthcare providers in a regulatory gray zone — protected by neither HIPAA's clinical data rules nor the financial sector's specific payment data requirements.

B. Gramm-Leach-Bliley and Its Inapplicability

The Gramm-Leach-Bliley Act (GLBA) requires financial institutions to protect non-public financial information. While it employs NIST-aligned administrative, technical, and physical safeguard requirements, GLBA applies only to financial institutions — banks, credit unions, insurers, and their affiliates.⁴ A hospital or physician practice is not a financial institution for GLBA purposes, even though it processes credit card payments from patients. The MPDPA closes this gap in the healthcare context, extending equivalent protection to healthcare providers that collect payment card data.¹

C. PCI DSS: Industry Standard, Not Law

PCI DSS is a contractual compliance standard imposed by payment card networks on merchants and processors. While it is enforced through card network fines and the potential loss of card-acceptance privileges, it is not a statute enforceable by state attorneys general or through private rights of action.¹¹ Individual patients harmed by a provider's failure to comply with PCI DSS have no direct cause of action under the standard itself. The MPDPA transforms the PCI DSS prohibition on unnecessary cardholder data storage into enforceable law, creates a private right of action for patients, and assigns enforcement authority to the Illinois Attorney General — all mechanisms absent from the purely contractual PCI DSS framework.¹

IV. Coercive "Card on File" Practices

A. The Consent Problem

A particularly egregious aspect of current practice is the routine requirement that patients place a credit card on file as a condition of scheduling or receiving care. Privacy in the United States has historically been understood as the "right to be let alone," a concept originating with Brandeis and Warren's 1890 law review article.⁴ This conception of privacy is fundamentally incompatible with a system in which patients must surrender financial data to receive medical treatment.

The MPDPA's Section 15(c) directly prohibits providers from requiring a card on file as a condition of care, and Section 20 mandates affirmative notification to patients that no card data is stored and that care cannot be denied for refusing to provide it.¹ These provisions address both the coercive dimension of the practice — the power imbalance between a patient who needs care and a provider who demands financial information — and the informational asymmetry that allows the practice to persist without patient awareness.

B. Privacy by Design Principles

The principle of "privacy by design" holds that privacy protections should be integrated into systems from the outset rather than grafted on after the fact.⁴¹⁴ The MPDPA operationalizes privacy by design in the payment context: by prohibiting storage entirely, it ensures that the harm — unauthorized access to retained cardholder data — cannot occur in the first place. A provider that never stores card data beyond the moment of one-time processing has no retained data for an attacker to steal. This is precisely the "data minimization" principle that underpins modern privacy frameworks, from the GDPR to the NIST Privacy Framework.¹⁴

The GDPR treats data subjects as owners of their own information and requires that controllers justify every instance of data retention.⁵ While the MPDPA does not adopt GDPR's full architecture, it reflects a compatible philosophy: healthcare providers have no legitimate need to retain cardholder data after a transaction is complete, and the risk to patients of such retention vastly outweighs any operational convenience to the provider.

V. Constitutional and Common Law Foundations

A. Fourth Amendment Backdrop

The Fourth Amendment's protection against unreasonable searches and seizures, as interpreted in *Katz v. United States* (1967) and extended in *Carpenter v. United States* (2018), reflects a constitutional recognition that individuals have a reasonable expectation of privacy in sensitive personal information.² In *Katz*, the Supreme Court established the "expectation of privacy" doctrine, holding that the Fourth Amendment protects people, not merely places, and that the government must obtain a warrant before accessing information in which an individual has a reasonable expectation of privacy.² In *Carpenter*, the Court further held that individuals retain a privacy interest even in data they share with third parties, at least when that data is as comprehensive and intimate as historical cell-site location information.²

While the Fourth Amendment directly governs only government action, the privacy values it embodies inform legislative judgments about what protections citizens deserve. If the Constitution's framers intended to protect "persons, houses, papers, and effects" from unreasonable intrusion, a state legislature acts consistently with those values when it protects citizens' financial information from unnecessary and unauthorized retention by their healthcare providers.

B. State Police Power and Patient Protection

States have broad police authority to regulate the healthcare industry for the protection of public health, safety, and welfare. Illinois has already demonstrated its willingness to exercise this power in the privacy domain through the Biometric Information Privacy Act (BIPA), which imposes strict limitations on the collection and retention of biometric identifiers.⁴ Illinois BIPA allows claims "even without actual damages" — an approach that reflects the legislature's judgment that certain privacy violations are inherently harmful regardless of quantifiable injury.⁴

The MPDPA adopts a similar philosophy. By authorizing private rights of action with "statutory damages and attorney's fees" under Section 25(d), the Act ensures that patients do not bear the burden of proving individualized financial harm to vindicate a right that is inherently important.¹ The Illinois legislature has established itself as a national trendsetter in data privacy legislation, and the MPDPA extends that tradition into the domain of healthcare payment security.⁴

VI. Enforcement Architecture and Proportionality

A. Tiered Civil Penalties

The MPDPA's enforcement scheme is carefully calibrated. Section 25 establishes negligent violations at civil penalties up to \$2,500 per violation and knowing or repeated violations at up to \$10,000 per violation.¹ This tiered structure reflects the well-established legal principle that culpability should drive sanction. A provider that inadvertently fails to implement compliant processes faces a lower financial consequence than one that knowingly continues prohibited storage practices or repeatedly violates the Act after notice.

Comparing the MPDPA's penalty structure to analogous statutes confirms its proportionality. The GDPR imposes fines up to 4% of global annual revenues or €20 million, whichever is higher — penalties that have driven large American companies to exit European markets entirely rather than bear the compliance burden.⁵ The MPDPA's per-violation structure is far more modest, creating meaningful deterrence without the risk of existential financial consequences for a small medical practice.

B. Attorney General Enforcement and Private Rights of Action

Section 25(c) grants the Illinois Attorney General authority to enforce the Act, providing a public law enforcement backstop that does not rely solely on individual patients to police compliance.¹ This is important because many patients will never know their card data was improperly stored unless a breach occurs. The Attorney General's enforcement authority enables systemic correction before harm materializes.

The private right of action under Section 25(d), coupled with attorney's fees provisions, ensures that the Act has teeth even when government enforcement resources are limited.¹ This approach parallels the Electronic Communications Privacy Act (ECPA), which provides for private civil recovery against those who improperly access stored electronic communications. Section 2520 of the ECPA allows civil recovery of statutory damages plus attorney's fees from those who intercept or unlawfully disclose electronic communications.⁶ The MPDPA applies identical logic

to healthcare payment data: the person whose data was improperly retained should have a direct legal remedy, not merely the hope that a regulator will act.

C. Whistleblower Protections

Section 30 of the MPDPA protects employees who report violations from retaliation.¹ This provision is critical because compliance failures in healthcare payment systems are often visible only to those who work within the organization. Whistleblower protection provisions have long been recognized as essential complements to regulatory enforcement regimes — they harness the informational advantages of insiders while protecting those who speak up from economic retaliation. The inclusion of this provision reflects mature legislative draftsmanship that anticipates the practical enforcement challenges of regulating internal data handling practices.

VII. The MPDPA as a National Model

A. Illinois as a Legislative Trendsetter

Illinois has established itself as a trendsetter for other states in privacy and data protection legislation.⁴ BIPA has spawned similar biometric privacy statutes in several other states and has been referenced by policymakers nationwide as a model for protecting emerging categories of sensitive personal information. The MPDPA has the same potential. As healthcare payment systems increasingly move toward stored-credential models and recurring billing arrangements, the absence of a clear prohibition on unnecessary cardholder data retention creates growing risk for patients in every state.

B. Alignment with Federal Privacy Trends

California's GDPR-inspired Consumer Privacy Act has become a de facto national standard because companies prefer uniform compliance to a patchwork of state-specific obligations.⁵ A similar dynamic could develop around the MPDPA: if Illinois enacts strong payment data protections for healthcare patients, large multi-state health systems may adopt MPDPA-compliant practices nationally rather than maintain separate procedures for Illinois patients. This "Illinois effect" would extend patient protections beyond the statute's formal geographic reach without requiring congressional action.

C. Filling the Gap Until Federal Action

The United States has no comprehensive federal privacy statute analogous to the GDPR.⁴⁵ Congress has repeatedly considered and failed to pass general consumer privacy legislation, and healthcare payment security has received even less federal attention than consumer data privacy generally. In this legislative environment, state action is not merely acceptable — it is necessary. The MPDPA follows a well-established pattern in American privacy law: states identify a gap, pass a targeted statute, and federal law eventually catches up. HIPAA itself was preceded by state health privacy laws; the GLBA's financial privacy provisions were preceded by state financial data protection statutes.

VIII. Anticipated Objections and Responses

A. Operational Burden on Providers

Critics may argue that prohibiting stored cardholder data imposes operational burdens on healthcare providers, particularly small practices that rely on recurring billing. The MPDPA directly addresses this concern in Section 15(d), which permits providers to use PCI-DSS-compliant third-party payment processors that prevent provider access to full card data.¹ This provision allows providers to maintain the ability to charge patients for services using tokenized payment systems — a standard, widely available, and often less expensive alternative to storing

raw cardholder data in-house.¹¹ The PCI DSS itself was designed to encourage exactly this approach. The operational argument against the MPDPA is therefore not an argument against the Act's goal, but a misunderstanding of the technological solutions the Act expressly permits.

B. Preemption Concerns

HIPAA contains an express preemption provision that displaces state law only when the state law is "contrary to" HIPAA — that is, when compliance with both is impossible or when the state law "stands as an obstacle" to HIPAA's purposes.¹² Because the MPDPA regulates payment card data rather than PHI, it operates in a domain that HIPAA does not occupy. There is no conflict between HIPAA's requirements and the MPDPA's payment data prohibitions; providers can fully comply with both simultaneously. The MPDPA is therefore not preempted by HIPAA, and its enactment would create complementary, not conflicting, regulatory obligations.

IX. Conclusion

The Illinois Medical Payment Data Protection Act addresses a genuine and growing cybersecurity threat with targeted, proportionate, and well-designed legal tools. Healthcare providers are the most expensive targets for data breaches in the United States, with average breach costs reaching \$9.77 million per incident in 2024 — the highest across all industries for the fourteenth consecutive year.⁸ The healthcare sector faces ransomware attacks at a rate that has increased by 278% in recent years.^{9,10} Payment card data stored by healthcare providers falls in a regulatory gap between HIPAA and PCI DSS, leaving patients financially exposed without adequate legal recourse.^{11,12} The MPDPA closes this gap by prohibiting unnecessary cardholder data storage, requiring patient notification, enabling both regulatory and private enforcement, and protecting the whistleblowers who are often the first to detect compliance failures.¹

The Act is consistent with Illinois's established role as a leader in privacy legislation,⁴ with the constitutional values underlying Fourth Amendment jurisprudence,² and with the data

minimization principles that animate modern frameworks from the GDPR to the NIST Privacy Framework.⁵¹⁴ It provides a practical, technologically neutral solution — permitting third-party payment processors while prohibiting raw data storage — that imposes modest costs on compliant providers and meaningful consequences on those who expose patients to unnecessary financial risk.¹¹¹ For these reasons, the MPDPA merits enactment, and its framework should serve as a model for other states seeking to protect patients from the intersection of healthcare and financial cybercrime.

References:

1. Illinois 104th General Assembly,
[Medical Payment Data Protection Act \(Proposed Legislation, 2027–2028\)](#)
2. [Katz v. United States, 389 U.S. 347 \(1967\)](#); [Carpenter v. United States, 585 U.S. 296 \(2018\)](#).
Texas A&M University School of Law, Cybersecurity Law Module 4 Video 1 Transcript: The Fourth Amendment in the Digital Age (2025).
3. Texas A&M University School of Law, Cybersecurity Law Module 4 Video 2 Transcript: Privacy Laws and Surveillance (2025). See [18 U.S.C. §§ 2510–2523, Electronic Communications Privacy Act](#).
4. Texas A&M University School of Law, Cybersecurity Law Module 4 Video 3 Transcript: State Privacy Laws (2025). See also [Illinois Biometric Information Privacy Act, 740 ILCS 14](#).
5. Texas A&M University School of Law, Cybersecurity Law Module 4 Video 4 Transcript: GDPR (2025). See also [General Data Protection Regulation \(EU\) 2016/679](#).
6. [18 U.S.C. §§ 2510–2523, Electronic Communications Privacy Act \(ECPA\)](#); see also 18 U.S.C. § 2520 (civil damages provision).
7. [18 U.S.C. § 1030, Computer Fraud and Abuse Act](#).
8. Chukwudi Okonkwo et al., "[Securing Healthcare Transactions in AI-Augmented Systems: A Comprehensive Framework for Enhanced Cybersecurity in Health Insurance Operations](#)," [The American Journals of Applied Sciences \(2025\)](#) (reporting \$9.77M average healthcare breach cost for 2024, highest across all industries for 14th consecutive year).
9. Sulaiman Almutairi et al., "[The Unseen Impact: A Critical Investigation of Healthcare Cybersecurity Breaches Using HHS Data](#)," [IEEE \(2025\)](#). See also U.S. Dept. of Health & Human

- Services, ASPR, [Healthcare Sector Cybersecurity Report \(Dec. 2023\)](#) (reporting 278% increase in ransomware attacks since 2018).
10. Abdulaziz Alanazi et al., ["Trends in U.S. Healthcare Data Breaches," IEEE \(2025\)](#) (analyzing HHS-OCR breach data 2019–2024).
 11. Payment Card Industry Security Standards Council, [PCI DSS v4.0 Resource Hub](#). See also [PCI SSC Document Library](#).
 12. [Health Insurance Portability and Accountability Act of 1996 \(HIPAA\), Pub. L. No. 104-191](#); Health Information Technology for Economic and Clinical Health (HITECH) Act, Pub. L. No. 111-5 (2009).
 13. [Computer Fraud and Abuse Act, 18 U.S.C. § 1030](#).
 14. National Institute of Standards and Technology, [Privacy Framework: A Tool for Improving Privacy Through Enterprise Risk Management, Version 1.0 \(2020\)](#); [NIST Cybersecurity Framework 2.0 \(2024\)](#).